

1. Overview

In Phase 3, we implemented a defensive mechanism to protect the SSH service of the victim (Metasploitable3) using **Fail2Ban**. We then reran the same brute-force attack from Phase 1 and 2, and analyzed the logs using Splunk to verify that the attack was detected and mitigated. Fail2Ban automatically banned the attacking IP address after repeated failed login attempts.

2. Defense Mechanism: Fail2Ban

Fail2Ban scans log files like `/var/log/auth.log` for signs of brute-force attacks. When it detects too many failed login attempts, it automatically updates firewall rules to **ban the attacker's IP address** for a set amount of time.

Step 1: Install Fail2Ban on Metasploitable3

```
sudo apt update
```

```
sudo apt install fail2ban -y
```

```
vagrant@metasploitable3-ub1404:~$ sudo apt install fail2ban -y
```

Step 2: Start Fail2Ban (Ubuntu 14.04)

```
sudo service fail2ban start
```

```
vagrant@metasploitable3-ub1404:~$ sudo service fail2ban start
* Starting authentication failure monitor fail2ban
```

Step 3: Configure Fail2Ban for SSH

Edited the configuration:

```
sudo nano /etc/fail2ban/jail.local
```

```
vagrant@metasploitable3-ub1404:~$ sudo nano /etc/fail2ban/jail.local_
```

Pasted the following config:

```
[sshd]
enabled = true
port = ssh
logpath = /var/log/auth.log
Filter = sshd
maxretry = 3
bantime = 600
```

A screenshot of the GNU nano 2.2.6 text editor. The title bar shows "GNU nano 2.2.6" and "File: /etc/fail2ban/jail.local". The editor content shows the following configuration for the [sshd] section: enabled = true, port = ssh, logpath = /var/log/auth.log, filter = sshd, maxretry = 3, and bantime = 600. At the bottom, there is a status bar with "[Read 7 lines]" and a row of keyboard shortcuts: ^G Get Help, ^O WriteOut, ^R Read File, ^Y Prev Page, ^C Cur Pos, ^X Exit, ^J Justify, ^W Where Is, ^U Next Page, ^U UnCut Text, and ^T To Spell.

Then saved.

Restarted Fail2Ban to apply the config:

```
sudo service fail2ban restart
```

```
vagrant@metasploitable3-ub1404:~$ sudo service fail2ban restart
* Restarting authentication failure monitor fail2ban [ OK ]
vagrant@metasploitable3-ub1404:~$ _
```

Step 4: Re-run the Brute Force Attack from Kali

From Kali, used Metasploit **with brute force wrong credentials first** (so that Fail2Ban kicks in):

```
sudo msfconsole
use auxiliary/scanner/ssh/ssh_login
set RHOSTS 192.168.0.181
set USER_FILE usernames.txt
set PASS_FILE passwords.txt
set VERBOSE true
run
```

```
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.0.181:22 - Starting bruteforce
[-] 192.168.0.181:22 - Failed: 'root:toor'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.0.181:22 - Failed: 'root:123456'
[-] 192.168.0.181:22 - Failed: 'root:vagrant'
[-] 192.168.0.181:22 - Failed: 'admin:toor'
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > █
```

As we can see Fail2ban is working and banned the ip after the third try.

Step 5: Check Ban Status and Logs

Check if the IP got banned:

```
sudo fail2ban-client status sshd
```

```
vagrant@metasploitable3-ub1404:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- filter
| |- File list:      /var/log/auth.log
| |- Currently failed: 1
| '- Total failed:   4
'- action
  |- Currently banned: 1
  |- IP list:         192.168.0.232
  '- Total banned:    1
vagrant@metasploitable3-ub1404:~$ _
```

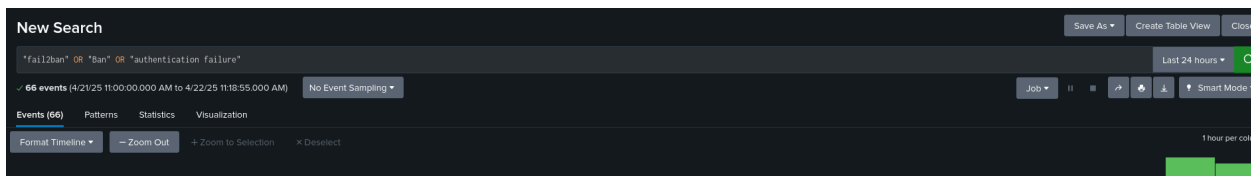
In Splunk:

Went to:

Search & Reporting → Data Summary → /var/log/auth.log

Used this search:

```
"fail2ban" OR "Ban" OR "authentication failure"
```



Found the fail2ban log banning after the 3rd attempt:

i	Time	Event
>	4/22/25 11:17:47.000 AM	Apr 22 08:17:47 metasploitable3-ub1404 sudo: vagrant : TTY=ttty1 ; PWD=/home/vagrant ; USER=root ; COMMAND=/usr/bin/fail2ban-client status sshd host = metasploitable3-ub1404 : source = /var/log/auth.log : sourcetype = syslog
>	4/22/25 11:16:31.000 AM	Apr 22 08:16:31 metasploitable3-ub1404 sshd[3494]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.232 host = metasploitable3-ub1404 : source = /var/log/auth.log : sourcetype = syslog
>	4/22/25 11:16:29.000 AM	Apr 22 08:16:29 metasploitable3-ub1404 sshd[3492]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.232 user=root host = metasploitable3-ub1404 : source = /var/log/auth.log : sourcetype = syslog

Step 6: Compare Before vs After

Before Defense

Successful login:
vagrant:vagrant

After Defense

Attack blocked, IP banned after 3
tries

Before:

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) >
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.0.181
RHOSTS => 192.168.0.181
msf6 auxiliary(scanner/ssh/ssh_login) >
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_FILE usernames.txt
USER_FILE => usernames.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE passwords.txt
PASS_FILE => passwords.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.0.181:22 - Starting bruteforce
[-] 192.168.0.181:22 - Failed: 'root:toor'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.0.181:22 - Failed: 'root:123456'
[-] 192.168.0.181:22 - Failed: 'root:vagrant'
[-] 192.168.0.181:22 - Failed: 'admin:toor'
[-] 192.168.0.181:22 - Failed: 'admin:123456'
[-] 192.168.0.181:22 - Failed: 'admin:vagrant'
[-] 192.168.0.181:22 - Failed: 'vagrant:toor'
[-] 192.168.0.181:22 - Failed: 'vagrant:123456'
[-] 192.168.0.181:22 - Success: 'vagrant:vagrant' 'uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo) Linux metasploitable3-ub1404 3.13.0-1'
[*] SSH session 1 opened (192.168.0.232:39889 -> 192.168.0.181:22) at 2025-04-22 10:03:09 +0300
[-] 192.168.0.181:22 - Failed: ':toor'
[-] 192.168.0.181:22 - Failed: ':123456'
[-] 192.168.0.181:22 - Failed: ':vagrant'
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > █
```

After:

```
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.0.181:22 - Starting bruteforce
[-] 192.168.0.181:22 - Failed: 'root:toor'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.0.181:22 - Failed: 'root:123456'
[-] 192.168.0.181:22 - Failed: 'root:vagrant'
[-] 192.168.0.181:22 - Failed: 'admin:toor'
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[-] Could not connect: The connection was refused by the remote host (192.168.0.181:22).
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > █
```

7. Summary & Findings

- Fail2Ban was successfully installed on Metasploitable3.

- The same SSH brute-force attack was executed from Kali.
- Fail2Ban detected repeated failed login attempts and **banned the attacker IP**.
- Splunk logs verified the detection and blocking behavior.
- The defense was **effective** in mitigating the attack.